

ESSENTIAL BANK

Établissement bancaire Bagnolet

PLAN DE REPRISE D'ACTIVITÉ (PRA)

Volet « reprise d'activité » du Plan de Continuité d'Activité

Cours : Infrastructure IT – Gouvernance, Audit et Risques
EFREI Paris | Année universitaire 2025-2026

Mai 2026

Document confidentiel – Usage pédagogique

I. Objet, périmètre et articulation avec le PCA

Ce PRA complète le Plan de Continuité d'Activité d'Essential Bank. Le PCA pose la stratégie d'ensemble (activités essentielles, besoins de continuité, analyse de risques EBIOS RM, moyens et procédures). Le PRA, lui, traite la phase qui suit le sinistre : comment Essential Bank redémarre ses activités, dans quel ordre et dans quels délais.

I.1 Définition et objet du PRA

Le Plan de Reprise d'Activité regroupe les mesures prévues pour rétablir l'activité après une interruption due à un incident (définition reprise de la norme ISO 22301). Il fait partie du PCA, dont il constitue le volet « reprise ».

Chez Essential Bank, tous les services bancaires (comptes, crédits, virements) reposent sur un SI centralisé hébergé sur Microsoft Azure. Le PRA est donc surtout informatique : son volet SI, le Plan de Reprise Informatique (PRI), est détaillé en section V.

I.2 Articulation PCA / PRA / PCI / PRI

On distingue quatre documents emboîtés. Le PCA est l'ensemble le plus large, le PRA en est le volet « reprise », le PCI est le volet SI du PCA, et le PRI est le volet SI du PRA. C'est ce dernier qui occupe l'essentiel de ce document.

Document	Rôle	Couverture chez Essential Bank
PCA	Stratégie globale de continuité, anticipation de la crise majeure	Document maître (5 directions, 4 sites)
PRA	Mesures de rétablissement de l'activité après interruption	Présent document
PCI	Volet SI du PCA (prévention, sauvegarde, détection, tests)	Intégré au PCA (sections II et V)
PRI	Volet SI du PRA : bascule, restauration, redémarrage du core banking	Section V du présent PRA

Le PRA d'Essential Bank intègre le PRI car, pour une banque 100 % cloud, la reprise métier est indissociable de la reprise du système d'information.

I.3 Périmètre couvert

Le PRA reprend le périmètre du PCA unique « tous risques » : les quatre sites (siège de Bagnole et trois agences), les cinq directions (DG, DRH, DAF, Marketing & Communication, DSI) et l'ensemble des processus bancaires. Il couvre la reprise après les scénarios EBIOS prioritaires (SO-01a à SO-04a) et après les scénarios physiques retenus dans le PCA : arrêt électrique, panne Telecom, incendie, inondation et crise sanitaire.

II. Objectifs de reprise et ordre de priorité

On ne redémarre pas tous les services en même temps. La reprise suit un ordre de priorité défini à l'avance, à partir des objectifs de continuité fixés dans le PCA. On rappelle ces objectifs ci-dessous avant de poser la séquence de reprise.

II.1 Rappel des objectifs de reprise (DMIA, RTO, PRMA/RPO, PDMA)

Les valeurs ci-dessous viennent du PCA (section V.1). Ce sont les cibles que les procédures de reprise doivent permettre de tenir. La DMIA globale est de 4 heures, fixée par le processus le plus critique (l'exploitation du SI) ; le PRMA est de 6 heures, calé sur la fréquence des instantanés Azure ; la PDMA reste inférieure à 6 heures de transactions.

Processus essentiel	Direction	DMIA	PRMA (RPO)	PDMA
Exploitation du SI (core banking, APIs paiement)	DSI	4 h	6 h	< 6 h de transactions
Communication institutionnelle et gestion de crise	DG / Mktg	2 h	N/A	N/A
Trésorerie et règlements critiques	DAF	24 h	6 h	< 6 h
Reporting réglementaire Banque de France	DAF	24 h	24 h	0 — aucune perte
Sécurité et réponse aux incidents (RSSI)	DSI	8 h	N/A	N/A
Sauvegarde, reprise et protection des données	DSI	24 h	6 h	0 — aucune perte client
Gestion de la paie et des contrats	DRH	4 h (J-5→J-1) / 48 h	24 h	0 en période critique
Mobilisation des équipes en crise	DRH	2 h	N/A	N/A
Gestion de la relation client (B2B/B2C)	Mktg / Com.	24 h	12 h	N/A

DMIA = Durée Maximale d'Interruption Admissible | RTO = Recovery Time Objective | PRMA/RPO = Point de Reprise Maximum Admissible | PDMA = Perte de Données Maximum Admissible.

II.2 Ordre de priorité de reprise des activités

La reprise se fait par paliers. Le palier P0 conditionne tous les autres : sans décideur ni SI, aucune activité métier ne peut repartir. Plus le RTO est court, plus l'activité est prioritaire dans la bascule.

Palier	Activités reprises	Justification de la priorité	Fenêtre cible
P0 — Pilotage	Cellule de reprise, décision stratégique (DG), mobilisation RH	Aucune reprise n'est possible sans décideur habilité ni équipe mobilisée	0 → 1 h
P1 — Vital	Core banking et APIs de paiement, surveillance sécurité (RSSI), communication de crise	Cœur de métier ; toute interruption au-delà de la DMIA est critique (G4)	1 → 4 h
P2 — Critique	Trésorerie et règlements prestataires, reporting Banque de France, relation client	Conséquences réglementaires et financières sous 24 h	4 → 24 h

Palier	Activités reprises	Justification de la priorité	Fenêtre cible
P3 — Important	Paie (hors période critique), comptabilité, sauvegardes complètes	Récupérable sous quelques jours sans sanction immédiate	24 → 72 h
P4 — Différable	Administration RH courante, campagnes marketing et acquisition	Impact faible (G1) ; reprise après stabilisation	> 72 h

Cet ordre constitue la « frise de reprise » d'Essential Bank. Il sert de référence à la cellule de reprise pour arbitrer l'allocation des moyens limités en début de crise.

III. Organisation de la reprise

Une cellule dédiée pilote la reprise dès le déclenchement du PRA. Elle est très proche de la cellule de crise du PCA : dans une structure de 30 personnes, les deux partagent l'essentiel de leurs membres, et le DSI, chef de projet PCA, en est aussi le pilote.

III.1 La cellule de reprise

Elle réunit les responsables capables de décider et d'agir sur les ressources critiques. Chacun a un suppléant désigné (matrice de suppléance RH) pour rester joignable à tout moment.

Rôle dans la reprise	Fonction	Responsabilités pendant la reprise
Pilote de la reprise	DSI	Déclenche le PRA, ordonne la séquence de bascule, valide la levée du mode dégradé et le retour à la normale
Responsable reprise SI	RSSI	Conduit la restauration technique, vérifie l'intégrité et l'absence de compromission avant remise en service
Responsable données & conformité	DPO	Contrôle l'intégrité des données restaurées, déclenche la notification CNIL/clients si nécessaire (72 h, art. 33 RGPD)
Responsable reprise financière	DAF	Rétablit les paiements critiques (Azure, Orange, Stripe) et le reporting Banque de France, évalue les pertes
Responsable reprise humaine	DRH	Mobilise les effectifs et suppléants, organise le télétravail et le repli inter-agences
Sponsor & décideur	DG	Déclare l'état de crise, arbitre les budgets d'urgence, représente Essential Bank auprès des autorités

III.2 Annuaire de reprise et chaîne d'alerte

L'annuaire de reprise reprend l'annuaire de crise du PCA. Il liste les coordonnées personnelles (mobile, email de secours) de chaque membre de la cellule et de son suppléant, ainsi que les contacts prestataires d'astreinte. On le garde sous deux formes : une copie numérique chiffrée sur Azure et une copie papier hors site (chez le DSI et le DG), pour qu'il reste accessible même si le SI est totalement indisponible.

- Contacts internes : DG, DSI, RSSI, DPO, DAF, DRH et leurs suppléants.
- Contacts prestataires d'astreinte : Microsoft Azure (support Premier), Orange Business (GTR contractuelle), Stripe, PayPal.
- Contacts autorités : ANSSI / CERT-FR, CNIL, correspondant Banque de France, assureur cyber.

La chaîne d'alerte se déroule ainsi : détection de l'incident (SIEM/EDR ou signalement), qualification par le RSSI, information du pilote (DSI), décision de déclenchement, puis convocation de la cellule via appel en cascade et SMS de masse.

III.3 Conditions de déclenchement du PRA

On déclenche le PRA quand un incident dépasse le traitement courant et menace une activité essentielle au-delà de sa DMIA. La décision revient au DSI, ou à son suppléant, après qualification par le RSSI. Les critères retenus sont les suivants :

- **Indisponibilité du core Banking non résolus après 30 minutes (seuil d'activation du mode dégradé défini au PCA).**

- Confirmation d'un chiffrage (rançongiciel) ou d'une compromission avérée du SI.
- Sinistre physique rendant un site inexploitable (incendie, inondation, coupure électrique prolongée).
- Perte de connectivité inter-sites empêchant l'accès aux services cloud sur l'ensemble du réseau.
- Indisponibilité massive de personnel sur les postes critiques (< 60 % d'effectif mobilisable).

Une fois le PRA déclenché, le DG déclare l'état de crise. Cela débloque les budgets d'urgence et permet d'activer les conventions de site de repli.

IV. Stratégies de reprise par scénario de sinistre

À chaque scénario prioritaire correspond une stratégie de reprise, choisie selon la nature de la perte (logique ou physique), la ressource touchée et le RTO visé. Le tableau associe à chaque scénario sa solution principale et le mode transitoire associé : contournement, mode secours, reprise à chaud ou à froid.

Scénario	Stratégie de reprise	Mode transitoire	RTO cible
SO-03a Rançongiciel	Isolement, restauration depuis sauvegarde saine, bascule Azure DR	Mode secours (lecture seule) puis reprise à froid restaurée	2 h
SO-03b Panne serveur	Bascule automatique (failover) vers l'instance Azure redondante	Reprise à chaud (haute disponibilité)	2 h
SO-01a Hameçonnage / exfiltration	Révocation des accès, rotation des secrets, reprise sur SI assaini	Contournement (accès restreint MFA)	4 h
Panne Telecom (Orange)	Bascule sur lien 4G/5G de secours, accès direct aux APIs cloud	Mode dégradé connectivité	< 4 h
Arrêt électrique prolongé	Onduleurs puis repli sur site/coworking, SI cloud non affecté	Mode secours sur site de repli	4 h
Incendie / sinistre site	Repli sur site de substitution ou télétravail, SI cloud préservé	Reprise à froid sur site de repli	4 h (SI) / 24 h (site)
Inondation (Bagnolet)	Évacuation, repli inter-agences, archivage numérique préservé	Reprise à froid délocalisée	24 h
Crise sanitaire	Activation du plan de télétravail d'urgence (VPN, suppléances)	Mode dégradé distribué	2 h

Reprise à chaud = bascule quasi immédiate sur système redondant déjà synchronisé. Reprise à froid = remise en service par restauration, avec délai plus long. Lignes rosées = scénarios cyber issus de l'analyse EBIOS RM.

À noter : une fois la bascule sur l'environnement de secours réalisée, on ne revient pas en arrière automatiquement. Le retour au fonctionnement normal suit une procédure dédiée, décrite en section VIII.

V. Plan de Reprise Informatique (PRI) — volet SI

Le PRI est la partie la plus opérationnelle du PRA. Il décrit l'architecture de reprise, les procédures de bascule et de restauration, l'ordre de redémarrage des systèmes et les contrôles d'intégrité à réaliser avant la remise en service.

V.1 Architecture de reprise

La reprise du SI repose sur le cloud Azure et sur une sauvegarde 3-2-1. La production tourne dans une région Azure principale, répliquée vers une région secondaire géographiquement distincte (Azure Disaster Recovery). Ainsi, un sinistre touchant une région n'affecte pas la copie de reprise.

- **Production : core Banking, base de données clients et transactions, APIs Stripe/PayPal, en région Azure principale.**
- **Réplication DR : instance miroir en région secondaire, basculable par failover (RTO cible 2 h).**
- **Sauvegardes 3-2-1 : 3 copies, 2 supports distincts (Azure + stockage chiffré local), 1 copie hors site (région Azure secondaire) ; instantanés toutes les 6 h (PRMA = 6 h).**
- **Connectivité de secours : routeurs 4G/5G sur chaque site pour préserver l'accès aux APIs cloud en cas de panne Orange Business.**

V.2 Procédure de bascule (failover) du core Banking

À appliquer en cas de panne matérielle (SO-03b) ou d'indisponibilité de la région Azure principale. L'objectif est une reprise à chaud.

1. Le RSSI confirme l'indisponibilité de l'instance principale et écarte une compromission (sinon : appliquer V.3).
2. Le pilote (DSI) ordonne le basculement vers l'instance Azure de la région secondaire.
3. Bascule du DNS / point d'entrée applicatif vers l'environnement de reprise ; vérification de la disponibilité des APIs de paiement (Stripe, PayPal).
4. Mise du portail client en mode lecture seul le temps de valider l'intégrité transactionnelle.
5. Tests fonctionnels (consultation de compte, virement test) puis ouverture progressive des écritures.
6. Communication interne aux directions : le SI est rétabli en mode secours ; communication client par la cellule Mktg si l'interruption a été visible.

V.3 Procédure de restauration depuis sauvegarde (rançongiciel)

À appliquer en cas de chiffrement ou de compromission avérée du SI (SO-03a / SO-01a). Le point clé : ne surtout pas restaurer une sauvegarde déjà compromise.

1. Isolement immédiat : segmentation VLAN, coupure des liaisons entre segments infectés et sains, gel des comptes suspects.
2. Qualification par le RSSI : périmètre du chiffrement, date de compromission présumée, identification du dernier instantané réputé sain (antérieur à la compromission).

3. Notification : information de l'ANSSI/CERT-FR ; le DPO prépare la notification CNIL (72 h) si des données personnelles sont concernées.
4. Restauration depuis le dernier instantané Azure sain dans un environnement assaini ; rotation de l'ensemble des secrets et identifiants (mots de passe, clés API).
5. Contrôle anti-réinfection (EDR) avant toute remise en réseau ; validation DPO de l'intégrité des données restaurées.
6. Réintégration progressive des services selon l'ordre de redémarrage (V.4) et réconciliation des transactions (V.5).

V.4 Ordre de redémarrage des systèmes

Le redémarrage suit une séquence précise : d'abord l'infrastructure et la sécurité, ensuite les services métier, enfin les services différables. Redémarrer dans le désordre exposerait à une réinfection ou à des incohérences de données.

Ordre	Système / composant	Pré-requis avant démarrage	Responsable
1	Réseau, pare-feu, segmentation VLAN, EDR	Liens (Orange ou 4G de secours) opérationnels	DSI / RSSI
2	Annuaire d'authentification, MFA, gestion des secrets	Secrets renouvelés si compromission	RSSI
3	Base de données clients et transactions	Intégrité de la sauvegarde validée (DPO)	DSI / DPO
4	Core banking (comptes, crédits, virements)	Base de données disponible et cohérente	DSI
5	APIs de paiement (Stripe, PayPal)	Core Banking opérationnel, clés API valides	DSI
6	Portail client et canaux agences	Tests fonctionnels du core Banking réussis	DSI / Mktg
7	Outils support (SIRH, comptabilité, CRM)	Services vitaux stabilisés	DSI / DAF / DRH

V.5 Réconciliation et contrôle d'intégrité des données

Avec un PRMA de 6 heures, jusqu'à 6 heures de transactions peuvent manquer entre le dernier instantané et le sinistre. Il faut les identifier puis les rejouer ou les ressaisir : aucune opération client ne doit être perdue définitivement (PDMA = 0 sur les données client).

1. Identification de la fenêtre de perte : écart entre l'horodatage du dernier instantané restauré et l'instant du sinistre.
2. Récupération des transactions en attente : journaux applicatifs, opérations enregistrées en mode dégradé (cache local, registres papier des agences).
3. Rejeu et réconciliation des écritures ; contrôle de cohérence des soldes de comptes.
4. Notification des clients dont une opération a été impactée ; validation finale de l'intégrité par le DPO avant clôture de la reprise des données.

VI. Procédures de reprise métier par direction

Une fois le SI rétabli, chaque direction reprend ses activités selon des actions définies à l'avance, en respectant l'ordre de priorité de la section II.2. Le tableau les résume par direction, avec la fenêtre cible.

Direction	Actions de reprise	Palier	Fenêtre
Direction Générale	Constituer la cellule de reprise, déclarer l'état de crise, arbitrer les priorités et budgets, assurer la représentation auprès de la Banque de France et de BPI France	P0	0 → 1 h
DSI / RSSI / DPO	Exécuter le PRI : bascule ou restauration, redémarrage séquencé, contrôle d'intégrité, rétablissement de la surveillance de sécurité	P1	1 → 4 h
Marketing & Com.	Publier la communication de crise, rétablir un canal client (téléphone/email), informer sur le rétablissement progressif	P1	1 → 4 h
DAF	Rétablir les paiements critiques (Azure, Orange, Stripe), reprendre le reporting Banque de France, chiffrer les pertes	P2	4 → 24 h
DRH	Confirmer la mobilisation des effectifs, sécuriser la paie si échéance proche, organiser le repli ou le télétravail durable	P2 / P3	selon échéance paie
DAF / DRH (courant)	Reprendre la comptabilité courante, l'administration RH et les campagnes marketing après stabilisation	P3 / P4	> 24 h

Chaque direction s'appuie sur des fiches « réflexes » propres à son métier (section VII), volontairement simples pour rester utilisables sous stress.

VII. Fiches réflexes de reprise par scénario

Les fiches réflexes traduisent les procédures en gestes immédiats : qui fait quoi, dans quel ordre et pour quel objectif de temps. Elles sont conservées en version numérique chiffrée et en version papier hors site.

FICHE 1 — Rançongiciel / chiffrement du SI (SO-03a) | RTO 2 h

1. Détecter et isoler : couper les liaisons réseau du segment infecté, geler les comptes suspects (RSSI).
2. Alerter : informer le pilote (DSI), l'ANSSI/CERT-FR ; le DPO arme la procédure de notification CNIL.
3. Identifier le dernier instantané Azure sain (antérieur à la compromission).
4. Restaurer dans un environnement assaini, renouveler tous les secrets et clés API.
5. Contrôler (EDR) l'absence de réinfection, valider l'intégrité des données (DPO).
6. Redémarrer selon l'ordre V.4, réconcilier les transactions, rouvrir le portail client.

Ne jamais restaurer une sauvegarde postérieure à la date de compromission présumée.

FICHE 2 — Panne matérielle / serveur central (SO-03b) | RTO 2 h

1. Confirmer la panne et écarter une compromission (RSSI).
2. Déclencher la bascule (failover) vers l'instance Azure redondante (DSI).
3. Rediriger le point d'entrée applicatif, vérifier les APIs de paiement.
4. Tester (consultation, virement test) puis rétablir les écritures.
5. Informer les directions et, si besoin, communiquer aux clients (Mktg).

FICHE 3 — Sinistre physique d'un site : incendie / inondation | RTO 4–24 h

1. Évacuer et sécuriser les personnes (priorité absolue), déclencher la cellule de reprise.
2. Confirmer que le SI cloud Azure n'est pas affecté (serveurs non localisés en agence).
3. Activer la convention de site de repli (coworking Bagnolet) ou le télétravail.
4. Rediriger les appels clients vers le numéro de secours (Mktg).
5. Redéployer le personnel sur les sites non sinistrés (DRH), rétablir les accès distants.
6. Déclarer le sinistre à l'assureur (DAF), planifier la remise en état du site.

FICHE 4 — Panne Telecom / Internet (Orange Business) | RTO < 4 h

1. Constater la perte de connectivité inter-sites (DSI).
2. Basculer sur les routeurs 4G/5G de secours pour maintenir l'accès aux APIs cloud.
3. Notifier Orange Business et activer la GTR contractuelle.

4. Passer les opérations bancaires non synchronisables en enregistrement différé (cache local).
5. Rétablir le lien principal, resynchroniser, contrôler la cohérence des transactions.

VIII. Retour à la normale

Revenir au fonctionnement normal est une étape à part entière, différente de la reprise en mode secours. Ce n'est pas automatique : le DSI ne décide ce retour qu'une fois sûr que les conditions d'un fonctionnement stable sont réunies. Revenir trop tôt exposerait à une rechute (réinfection, nouvelle coupure).

VIII.1 Conditions préalables

- Cause racine du sinistre identifiée et traitée (correctif, remise en état du site, secrets renouvelés).
- Intégrité et complétude des données confirmées par le DPO ; transactions réconciliées (PDMA respectée).
- Surveillance de sécurité pleinement opérationnelle (RSSI) ; aucun signal de compromission résiduelle.
- Environnement de production principal restauré et testé.

VIII.2 Séquence de retour

1. Validation formelle des conditions préalables par la cellule de reprise.
2. Bascule planifiée de l'environnement de secours vers la production principale, en heures creuses si possible.
3. Vérification fonctionnelle complète avant levée du mode dégradé.
4. Levée officielle du mode dégradé et clôture de l'état de crise par le DG.
5. Communication de clôture aux clients, partenaires et autorités (Banque de France, CNIL si une notification avait été ouverte).

VIII.3 Retour d'expérience (RETEX) immédiat

Dès la fin de la crise, on réalise un RETEX à chaud : chronologie des événements, écarts entre RTO/RPO visés et réels, difficultés rencontrées, décisions efficaces ou non. Ses conclusions servent à mettre à jour le PRA et à alimenter l'amélioration continue (section IX).

IX. Tests, maintenance et amélioration continue du PRA

Un PRA qui n'est jamais testé ne servira pas à grand-chose le jour J. Essential Bank l'inscrit donc dans un cycle régulier de tests et de révisions, en cohérence avec les exigences de DORA (tests réguliers de continuité) et avec l'amélioration continue du PCA.

IX.1 Programme de tests

Type de test	Objet	Fréquence	Responsable
Test de restauration	Restaurer un instantané Azure et vérifier l'intégrité des données	Mensuelle	DSI / DPO
Test de bascule (failover)	Basculer le core banking sur la région Azure secondaire	Trimestrielle	DSI
Test du lien de secours	Basculer sur 4G/5G et vérifier l'accès aux APIs cloud	Trimestrielle	DSI
Exercice de reprise complet	Simulation de rançongiciel, mesure RTO/RPO réels vs cibles	Annuelle	DSI / RSSI
Exercice de gestion de crise	Mobilisation de la cellule, jeu de rôle (réflexe ANSSI)	Annuelle	DG / RSSI
Test du plan de télétravail	Vérifier VPN, accès distants et matrice de suppléance	Annuelle	DRH / DSI

IX.2 Indicateurs de suivi

- RTO réel par processus, comparé à la cible (écart en %).
- RPO réel mesuré lors des tests de restauration.
- Taux de réussite des bascules et restaurations testées.
- Délai de mobilisation effectif de la cellule de reprise.
- Nombre de fiches réflexes à jour et taux de personnel formé.

IX.3 Maintenance documentaire

Le PRA est revu au moins une fois par an, et après chaque exercice, chaque incident réel et chaque évolution importante du SI ou de l'organisation (nouveau prestataire, nouveau site, changement réglementaire). Chaque révision est validée par la Direction Générale, responsable au final au titre du principe d'accountability. Cette boucle permet de garder le PRA aligné sur les objectifs, les menaces et le cadre réglementaire (DORA, RGPD, NIS 2).